

VENDOR X CORPORATION

SECURITY & COMPLIANCE QUESTIONNAIRE ASSESSMENT FOR NORTHSTAR FINANCIAL

DOCUMENT ID	ASSESSMENT FRAMEWORK	TARGET ENVIRONMENT	REVIEW STATUS
SEC-QST-2025-X99	SIG Lite / SOC 2 Type II	Single-Tenant VPC	Passed / Verified

1. EXECUTIVE SUMMARY & ATTESTATION

Vendor X Corporation maintains rigorous information security management systems designed to safeguard sensitive institutional data. This security questionnaire response outlines our architectural safeguards, encryption protocols, access governance policies, and disaster recovery procedures evaluated for Northstar Financial Services (NFS).

CONTROL DOMAIN	VENDOR X IMPLEMENTATION STANDARD	COMPLIANCE
SOC 2 Type II	Annual independent third-party audit covering Security, Availability, and Confidentiality trust services criteria.	Certified
ISO/IEC 27001	Comprehensive Information Security Management System (ISMS) governing operations and cloud infrastructure.	Certified
Data Residency	All customer data and vector embeddings reside strictly within US-East/US-West AWS GovCloud/Enterprise enclaves.	Enforced
Encryption Standards	AES-256 encryption at rest (KMS customer-managed keys) and TLS 1.3 in transit across all internal/external microservices.	Enforced

2. INFRASTRUCTURE SECURITY & TENANT ISOLATION

Vendor X utilizes a secure multi-tenant architecture with logical separation, alongside dedicated single-tenant Virtual Private Cloud (VPC) options for enterprise clients requiring extreme isolation.

- Network Segmentation:** Production, staging, and corporate IT networks are strictly isolated via AWS Security Groups, Network ACLs, and internal firewalls with zero direct routing between environments.
- Vulnerability Management:** Automated static application security testing (SAST), dynamic testing (DAST), and dependency scanning run on every code commit. Weekly external penetration tests are executed by accredited third-party cybersecurity firms.
- DDoS Mitigation:** Cloudflare Enterprise and AWS Shield Advanced are deployed at the edge to protect API endpoints and model execution routing nodes against volumetric attacks.

Zero Data Retention Policy for AI Training: Vendor X explicitly certifies that no customer data, prompts, context inputs, or generated outputs are utilized to train foundational LLMs or shared across client boundaries.

3. ACCESS CONTROL & IDENTITY GOVERNANCE

Access to Vendor X infrastructure and client data enclaves is strictly regulated following the principle of least privilege and zero-trust design paradigms.

GOVERNANCE CONTROL	OPERATIONAL MECHANISM	STATUS
Identity & Access Management	Mandatory Okta SSO integrated with enterprise hardware-token multi-factor authentication (MFA / FIDO2).	Active
Privileged Access Management	Just-In-Time (JIT) ephemeral access for DevOps engineers, requiring dual-person peer approval and full session recording.	Active
Background Screening	All engineering and support personnel undergo comprehensive criminal, financial, and employment background checks prior to onboarding.	Mandatory

4. BUSINESS CONTINUITY & DISASTER RECOVERY

Vendor X maintains a robust Business Continuity and Disaster Recovery (BCDR) plan designed to ensure continuous service availability and rapid recovery during unforeseen infrastructure disruptions.

- **Backup Procedures:** Automated encrypted snapshots of all databases and vector indexes occur hourly, replicated synchronously across multi-region AWS availability zones.
- **Recovery Objectives:** Guaranteed Recovery Point Objective (RPO) of < 15 minutes and Recovery Time Objective (RTO) of < 60 minutes for core platform services.
- **Annual Simulation:** Full failover disaster recovery tests are conducted annually under audit observation, with results available to NFS compliance officers upon request.

5. INCIDENT RESPONSE & SECURITY NOTIFICATION

In the event of a verified security incident affecting Northstar Financial Services data, Vendor X adheres to a strict notification protocol:

- **Immediate Alerting:** Designated NFS security liaisons will be notified within **24 hours** of confirming any unauthorized access or data exposure event.
- **Incident Root Cause Analysis:** A comprehensive forensic report and remediation action plan will be delivered within 5 business days of incident containment.